

## AITEE HUB • CYBERSECURITY Capstone 1: Healthcare Security Assessment

AITEE Community Health Center is a rapidly growing healthcare provider operating with 50 employees (doctors, nurses, administrative staff) and a small internal IT team. Their technical setup includes patient registration software, Electronic Health Records (EHR), staff laptops, Wi-Fi networks, corporate email, and a basic server environment.

### Current Security Audit Findings:

| Domine           | Observed vulnerability /current state                                                                 |
|------------------|-------------------------------------------------------------------------------------------------------|
| 1.Passwords      | Employees use simple, easy-to-guess passwords and reuse credentials across personal and work accounts |
| 2.Authentication | Multi-Factor Authentication (MFA) is not enforced on critical systems or administrative accounts      |
| 3.User Awareness | Employees have received no official cybersecurity awareness or phishing simulation training           |

Domine      Observed vulnerability/Current state

|                      |                                                                                        |  |  |
|----------------------|----------------------------------------------------------------------------------------|--|--|
| 4.Patching &Updates  | Operating systems, software applications, and connected systems are updated regularly. |  |  |
| 5. Data protection   | Unencrypted sensitive medical data is stored electronically on shared network drives.  |  |  |
| 6. Backup strategy   | Backups are taken occasionally, but data restoration procedures are never tested       |  |  |
| 7. Wireless security | Staff, corporate laptops, and guest visitors share the same wireless network           |  |  |
| 8.Access control     | Excessive access permissions: employees can access files beyond their job duties       |  |  |

## Task 1: Asset Identification & CIA Triad

### PART 03

An Asset is anything of value to the organization that requires protection. Analyze assets through the CIA Triad lens: Confidentiality (privacy), Integrity (accuracy), and Availability (uptime).

Task Instructions: Identify 5 key assets from the scenario. Fill out the table with the asset name

| Access name                     | Why it is important                                                                                             | What Could Happen If Lost/Compromised                                    |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| Patient record for example      | Contain sensitive medical history and personal data                                                             | Privacy breach, severe legal fines, patient trust lost                   |
| 1.Patient Registration Software | Stores and manages patient information and helps staff register and identify patients accurately.               | Loss of patient information, incorrect registration, delays in treatment |
| 2. Staff laptop                 | Used by doctors ,nurses and administrative staff ,to access patients records and emails.                        | Unauthorised access to their EHR system and malware infection            |
| 3.Corporate Email               | Used for communication between staff and may contain sensitive patient information.                             | Phishing attacks, unauthorized access to hospital systems                |
| Server Environment              | Stores and supports important applications, databases, and hospital information needed for daily operations.    | Ransomware attacks, and loss of access to critical information.          |
| WiFi network                    | Provides network connectivity for staff laptops, EHR systems, patient registration software, and other devices. | Healthcare operations could be disrupted if the network goes down.       |

## Task 2: Threat Identification

A Threat is any potential event or actor that could exploit a system to cause harm. (e.g., Phishing, Ransomware, Insider Threat, Device Theft, Hardware Failure, Power Outage).

Task Instructions: Identify 5 realistic threats facing AITEE Health Center

| Threat vector               | What system/Assets Could it affect ?                           | Possible impact /consequences                                                                                              |
|-----------------------------|----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Phishing emails ( example ) | Employees email account and laptop .                           | Credentials stolen, initial network access gain .I                                                                         |
| 1.Ransomware Attack         | EHR, servers, staff laptops, and patient registration software | Patient records will be encrypted, Systems will become unavailable, and healthcare services could be disrupted.            |
| 2.Insider Threat            | Electronic health record, Patient records and server           | An employee could accidentally or intentionally expose, , or delete sensitive patient information.                         |
| 3.Device Theft              | Staff laptops                                                  | Confidential patient information could be accessed by unauthorized persons, especially if devices are not properly secured |
| 4.Power Outage              | Wi-Fi network, EHR, and patient registration systems           | Systems could go offline, causing delays in patient care and disruption of normal operations.                              |
| 5.Hardware Failure          | Servers, staff laptops, storage devices, and network equipment | Loss of access to important systems or data, delays in healthcare services.                                                |

### Task 3 & 4: Vulnerabilities & Risk Mapping

Page 3 of 6A Vulnerability is a weakness in system design, process, or training. Risk occurs when a threat exploits a vulnerability to impact an asset.

ASSET+threat+ Vulnerability=Risk

Part 3: Identify 5 Vulnerabilities from Scenario

| Vulnerability (weakness)                                                | Related threat vector          | Why it is dangerous ?                                                                    |
|-------------------------------------------------------------------------|--------------------------------|------------------------------------------------------------------------------------------|
| Weak/Reused password<br>(example)                                       | Account compromised            | Attackers easily brute force or guess credentials                                        |
| 1. Outdated Software                                                    | Ransomware                     | Attackers can exploit known security weaknesses in unpatched software                    |
| 2. Poor Wi-Fi Security                                                  | Unauthorized Network Access    | Attackers may gain access to the network and connected systems.                          |
| 3. Lack of Employee Security Awareness<br>Phishing / Social Engineering | Phishing or social engineering | Employees may click malicious links or reveal sensitive information.                     |
| Lack of Regular Data Backups                                            | Ransomware or Hardware Failure | Important patient data could be lost or become unavailable after an attack               |
| 5. Lack of Access Controls                                              | Insider threat                 | Employees may access patient information or systems that they do not need for their job. |

#### Part 4 define 5 security Risk

| Identified Risk scenarios      | What System/ Data Affected?                                      | Why does it matter ?(Business Impact)                                                                                                        |
|--------------------------------|------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| 1.Patient Days Breach          | EHR, patient records, and registration software                  | Sensitive patient information could be exposed, leading to loss of trust.                                                                    |
| 2.Resomeware Attack Breach     | EHR, servers, staff laptops, and patient registration systems    | Systems could become unavailable, preventing staff from accessing patient records and disrupting healthcare services                         |
| 3. Phishing                    | Corporate email, employee accounts, laptops, and EHR             | Stolen credentials could allow attackers to enter the network and access sensitive information.                                              |
| 4. Unauthorized Network Access | Wi-Fi network, connected laptops, servers, and EHR               | Attackers could access internal systems, steal data, install malware                                                                         |
| 5. Data Loss or System Failure | Servers, databases, patient records, and healthcare applications | Loss of important records could interrupt patient care, cause financial losses, and reduce the organization's ability to operate effectively |

**Part 5: Prioritize Top 3 Critical Risks**Evaluate Likelihood (Low/Medium/High) and Impact (Low/Medium/High). Focus immediate resources on HighLikelihood + High Impact risks.

| Top Risk scenario        | Likelihood | Impact | Priority Level |
|--------------------------|------------|--------|----------------|
| 1.Ransomwar<br>e attack  | High       | High   | Critical       |
| 2.Patient<br>Data Breach | High       | High   | Critical       |
| 3.phishing               | High       | High   | Critical       |

## Justification

AITEE Health Center should address these three risks first because they can cause serious damage to patient safety, confidential information, and daily healthcare operations.

**Ransomware Attack:** It could lock important patient records and systems, preventing doctors and nurses from accessing information needed for patient care.

**Patient Data Breach:** Patient records contain highly sensitive personal and medical information. A breach

could result in legal consequences, financial losses, and loss of patient trust.

**Phishing / Account Takeover:** Phishing is a common way attackers gain access to employee accounts. A compromised account could provide attackers with access to emails, patient information, and other internal system

**Part 6: Recommend Security Controls**Categorize recommendations into: Administrative (policies, training), Technical (MFA, firewalls, encryption,backups), or Physical (locks, guards

| Identified Risk | control type    | Recommended control                                | How it reduces risk                                                                      |
|-----------------|-----------------|----------------------------------------------------|------------------------------------------------------------------------------------------|
| Weak password   | Technical/admin | Enforce MfA/password policy                        | Block 99% of automated logins attacks                                                    |
| Device Theft    | Physical        | Use secure locks + device encryption + remote wipe | Makes stolen devices harder to access and protects sensitive information stored on them. |
| Phishing        | Technical       | Conduct security awareness training +              | Helps employees recognize phishing                                                       |



|                           |           |                                                                                                                                                     |                                                                                                             |
|---------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
|                           |           | email filtering                                                                                                                                     | attempts and blocks many malicious emails before they reach users                                           |
| Ransomware Attack         | Technical | Implement regular offline backups + endpoint protection<br>Allows the health center to recover important data and helps detect or block ransomware. | Allows the health center to recover important data and helps detect or block ransomware.                    |
| Patient Data Breach       | Technical | Implement regular offline backups + endpoint protection                                                                                             | Allows the health center to recover important data and helps detect or block ransomware                     |
| Unauthorized Wi-Fi Access | Technical | Use strong Wi-Fi encryption + firewall + secure passwords                                                                                           | Prevents unauthorized users from connecting to the network and helps protect data moving across the network |

## Task 7: Executive Summary Writing Guide

The security posture assessment of AITEE Community Health Center revealed several vulnerabilities that could affect patient information, healthcare operations, and the organization's reputation. The assessment identified weaknesses such as weak or reused passwords, poor Wi-Fi security, outdated software, limited employee security awareness, lack of access controls, and inadequate data backups.

The primary risks threatening AITEE Health Center include ransomware attacks, patient data breaches, and phishing/account takeovers. These risks have been rated as High Likelihood and High Impact because they could expose sensitive patient information, make critical systems unavailable, disrupt patient care, and result in financial and legal consequences.

To reduce these risks, management should prioritize Multi-Factor Authentication (MFA), employee phishing-awareness training, regular and secure data backups, strong access

controls, encryption of sensitive patient information, and improved Wi-Fi security. Regular software updates and security assessments should also be implemented. By investing in these controls, AITEE Community Health Center can strengthen its security posture, protect patient confidentiality, maintain the accuracy and availability of healthcare information, and ensure continuity of healthcare services.